

SEC-STD-ZONES-001 - OT Network Segmentation and Zone Standard (APPROVED)

Synthetic training document. Not for operational use.

Document ID: SEC-STD-ZONES-001 | Version 1.1 | Status: APPROVED | Effective: 2025-10-01 | Owner: Plant Cyber Security | Approver: Head of Engineering

1. Purpose

Defines the trust zones for plant assets and the rules for traffic between them. The zone list is held in the `security_network_zones` table.

2. Zones

Zone	Description	Level
Z-L0	Field devices: sensors and actuators	Level 0
Z-L1	Basic control: controllers and condition-monitoring gateways	Level 1
Z-L2	Supervisory: HMI and SCADA	Level 2
Z-L3	Operations: historian and engineering workstations	Level 3
Z-DMZ	Industrial DMZ: remote access and data transfer	Level 3.5
Z-L4	Enterprise IT	Level 4-5

3. Exposure classes

- Internal: reachable only from inside the plant network.
- Restricted: reachable from outside through a controlled, logged remote access path in the DMZ.
- External: reachable from outside the plant through the DMZ with a service published to the corporate or vendor network.

An asset moves from Internal to Restricted or External only with a written exception approved by the Head of Engineering.

4. Traffic rules

- No direct traffic from Z-L4 or from outside the plant to Z-L1 or Z-L0. It must pass through the DMZ.
- Remote sessions end in the DMZ and are brokered into Z-L3. They are time-boxed and recorded.
- Outbound transfers from Z-L1 to external addresses are denied by default. Backups go to an internal backup server only.
- Unapproved scanning is prohibited. Approved scans run from the registered scanner address under a change ticket.

5. Review

Zone membership and exposure class are reviewed every six months and after any incident that involved lateral movement.